

The Harvester

Introduction

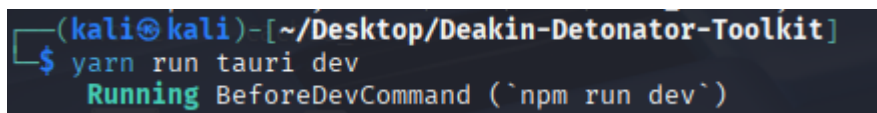
The Harvester is Open-Source Intelligence tool (OSINT) which targets domains and can identify subdomains, email address, IP address and hostnames associated with a targeted domain. The Harvester employs source including search engines and other information repositories to enable data scraping from targeted domains. These sources can be customised.

Disclaimer

Only run this tool against networks, systems and files that you own or those that you have explicit written permission to perform security assessments against. Attempting reconnaissance against third party systems without explicit permission is unethical. Most scans performed with The Harvester are legal as the information gathered is publicly available. However it is critical to verify this is applicable in your region. Best practice is to assume it is illegal to scan without express permission.

Setup and launch

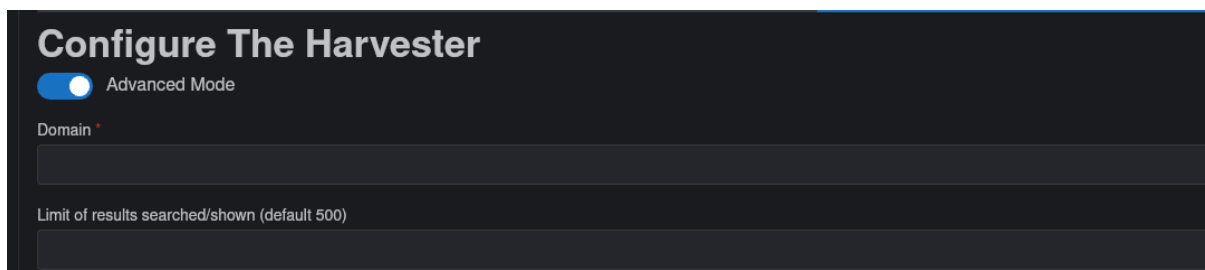
Initialise your virtual machine or device and open the terminal. Navigate to the directory where the Deakin Detonator Toolkit is installed. Then enter the following command into the terminal "yarn run tauri dev".



```
(kali@kali)-[~/Desktop/Deakin-Detonator-Toolkit]  
$ yarn run tauri dev  
Running BeforeDevCommand (`npm run dev`)
```

Once the startup process has completed accept the user agreement and then navigate to the upper left hand of the Deakin Detonator Toolkit GUI and click on the tools button. Once in the tool selection screen select The Harvester or use the quick search feature to access The Harvester, then proceed to the tool's configuration panel.

Configuration and Deployment



Configure The Harvester

☒ Advanced Mode

Domain *

Limit of results searched/shown (default 500)

Once The Harvester has initialised the first option available is the Domain input. Domain names and IPv4 addresses are valid inputs for the implementation in the

Deakin Detonator Toolkit. When using the harvester in a custom configuration IPv6 functionality can be implemented however there is limited support for the feature.

The second input allows the user to limit or expand the number of results shown during output. The default value is 500 results. This input accepts numerical values. Higher values are useful in the first stage of information gathering and lower values are preferable as the scope of an investigation shrinks.

The advanced mode toggle enables access to a new set of options that enhance The harvester's scanning capabilities.

Source

Baidu

Baidu
Bing
Censys
Certspotter
Crtsh
DNSdumpster
DuckDuckGo
Exalead
Google
Hackertarget
Hunter
Intelx
LinkedIn
LinkedIn Links
Netcraft
Otx
SecurityTrails
Shodan
Spyse
Sublist3r
Threatcrowd
Threatminer
Trello
Twitter
Vhost
Virustotal
Yahoo

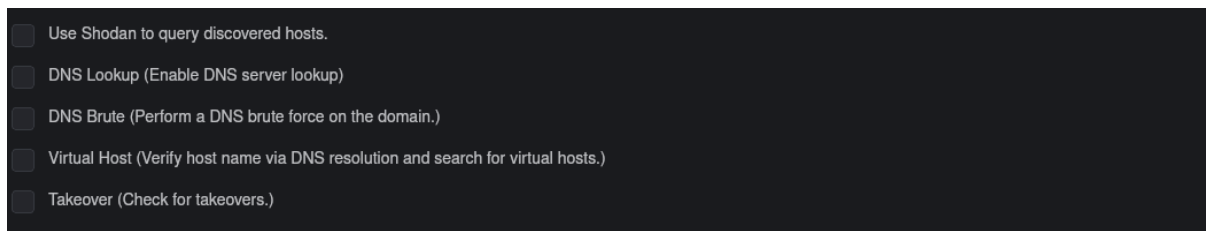
This field is critical it is the source that The Harvester will draw from while performing scans and gathering information. There are myriad sources to choose however it is important to note that not all sources will provide results for every domain.

Furthermore, many of the sources require or are significantly enhanced with access to a relevant API key. When using a The Harvester externally to the Deakin Detonator Toolkit it is possible to use all sources at once using the flag “-b all”.

Start with result number X. (default 0)

0

The input above sets the result to start from. The default is zero. Numerical values are valid inputs. Use this if the first expected entries are of no use or already catalogued.



Option one:

Once The Harvester discovers IP addresses, Shodan is triggered to retrieve service and banner information including open ports, software versions and running services.

Option two:

Enables DNS server lookup which performs forward and reverse DNS queries to confirm the validity of IP address to hostname mappings. This option will also gather CNAMEs. This will generate DNS traffic and will be detectable.

Option three:

DNS brute executes a dictionary-based subdomain scan against a target domain to discover common subdomains that are likely to exist. This produces a considerable volume of DNS queries and runs an elevated risk of triggering alerts or misinterpreting wildcard DNS records as valid subdomains.

Option four:

The Virtual host option attempts to determine if a single IP address hosts multiple site names, these site names are used in name based virtual hosting environments. The Harvester will resolve the individual hostnames and perform probing operations against HTTP host headers. This process can identify web-based assets hidden behind shared IP addresses. The probing process is risky as it is more likely to be detected than a passive lookup.

Option five:

The takeover option must be used cautiously. This option searches for dangling DNS entries, CNAMEs and misallocated cloud resources such as previously provisioned or ineffectively purged S3 buckets. This dangling resource could pose a significant risk of subdomain takeover. When receiving a positive result, it must be manually verified and must be done with explicit permission and should not be attempted without it or if it falls outside of or into a grey area of an authorised penetration test [1].

Once The Harvester is configured as desired click the button below:



Additional Flags

The Harvester implementation in the Deakin Detonator Toolkit does not allow custom scan options. However, when using The Harvester with Kali or other toolkits the following options can be used in addition to those enabled in the toolkit [2]:

--dns-server	Implements a custom DNS resolver for lookups.
--dns-tld	Enables DNS discovery across different top-level domains.
--screenshot	Captures screenshots of discovered web hosts.
--list-sources	Displays the full list of supported sources and modules.
--version	Display the version Harvester currently installed.
--quiet	Reduces the volume of information displayed in the terminal.
--dns-brute-wordlist	Specifies a custom wordlist when performing brute force DNS mapping.
--proxy	Designates a proxy that harvester will route traffic through.
--max-retries	Sets the number of failed network queries before ignoring a target.
--format	Forces and output format when supported.

Output

The output below is expected from a successful scan.

```
Output has been saved!
Output save file: /home/jd700194721/Desktop/The_Harvester_Test_700194721.txt

Output

[*] Hosts found: 5

-----

assessment.infosectrain.com:103.20.214.236

feedback.infosectrain.com:103.20.214.236

learn.infosectrain.com:103.20.214.236

links.infosectrain.com:103.20.214.236
```

The output will vary depending on previous configuration steps and the targeted domain. This scan successfully discovered five hosts four of which are visible. These hosts display the domain name and IP addresses associated with those domain names. I used the following configuration to gather this information:

Configure The Harvester

☒ Advanced Mode

Domain *

infosectrain.com

Limit of results searched/shown (default 500)

Source

SecurityTrails

Start with result number X. (default 0)

0

☒ Use Shodan to query discovered hosts.

☒ DNS Lookup (Enable DNS server lookup)

☐ DNS Brute (Perform a DNS brute force on the domain.)

☒ Virtual Host (Verify host name via DNS resolution and search for virtual hosts.)

☐ Takeover (Check for takeovers.)

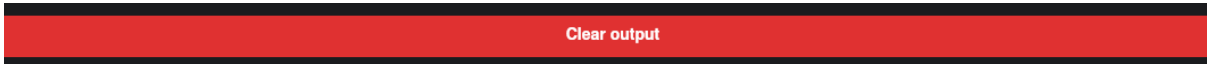
I saved the results to a text file using the “Save as Text File” button.

Save as Text File (.txt)

Below is the text output from the Deakin Detonator Toolkit implementation. This will be identical to output generated by alternative implementations of The Harvester.

```
1 $ theHarvester -d infosectrain.com -l 500 -b hackertarget -s -n
2
3
4
5 Read proxies.yaml from /etc/theHarvester/proxies.yaml
6
7 *****
8
9 * _ _ _ _ _ *
10
11 * | | | | _ _ _ _ ^ \ _ _ _ _ _ _ _ _ | | _ _ _ _ *
12
13 * | _ | _ \ / _ \ / / / _ ` | ' _ \ \ / / _ v _ | _ / _ \ ' _ | *
14
15 * | | | | | _ / / _ / ( | | | \ v / _ \ _ \ || _ / | *
16
17 * \ _ | | | \ _ | v / / \ _ , _ | \ / \ _ || _ \ _ \ _ | *
18
19 *
20
21 * theHarvester 4.8.2
22
23 * Coded by Christian Martorella
24
25 * Edge-Security Research
26
27 * cmartorella@edge-security.com
28
29 *
30
31 *****
32
33
34
35 [*] Target: infosectrain.com
36
37
38
39 [*] Searching Hackertarget.
40
41
42
43 [*] No IPs found.
44
45
46
47 [*] No emails found.
48
49
50
51 [*] No people found.
52
53
54
55 [*] Hosts found: 5
56
57 _____
58
59 assessment.infosectrain.com:103.20.214.236
60
61 feedback.infosectrain.com:103.20.214.236
62
63 learn.infosectrain.com:103.20.214.236
64
65 links.infosectrain.com:103.20.214.236
66
67 lms.infosectrain.com:103.20.214.236
68
69
70
71 [*] Starting active queries for DNSLookup.
72
73
74
75 [*] Hosts found after reverse lookup (in target domain):
76
77 _____
78
79 [*] Searching Shodan.
80
81
82 Process completed successfully.
```

To clear the output and start the process again, click the clear output button and then select a new target, ensuring to clear the current fields manually or by closing The Harvester and selecting the tool once again from the tool selection screen.



Troubleshooting

The primary issue most users face is poorly configuring API keys or failing to implement any at all. The Harvester will alert the user at installation, after scans, at startup and during configuration to ensure they have configured the API component of the tool appropriately. Most sources are inoperable or have extremely limited operational value without an API key.

References

- [1] Microsoft, "Prevent dangling DNS entries and avoid subdomain takeover," Microsoft, 16 April 2025. [Online]. Available: <https://learn.microsoft.com/en-us/azure/security/fundamentals/subdomain-takeover>. [Accessed 11 September 2025].
- [2] Offensive Security, "The Harvester," Offensive Security, 2025. [Online]. Available: <https://www.kali.org/tools/theharvester/>. [Accessed 11 September 2025].